

PENETRATION TESTING REPORT

Cybersecurity & Ethical Hacking Internship

Task 4: Exploitation & Web Application Security Testing

1. Objective

The objective of this task was to understand web application security testing concepts and perform security assessment activities in a controlled laboratory environment. The testing was conducted using OWASP Juice Shop and industry-standard security tools to observe web application behavior, analyze HTTP requests, perform directory discovery, and study common web vulnerabilities.

2. Tools Used

- Kali Linux
- Docker
- OWASP Juice Shop
- Burp Suite Community Edition
- Dirsearch
- Firefox Browser

3. Test Environment

A local web application security testing environment was created using OWASP Juice Shop running inside a Docker container on Kali Linux. Burp Suite was used for intercepting and analyzing HTTP traffic, while Dirsearch was used for directory and endpoint discovery.

4. Activities Performed

Activity 1: OWASP Juice Shop Setup

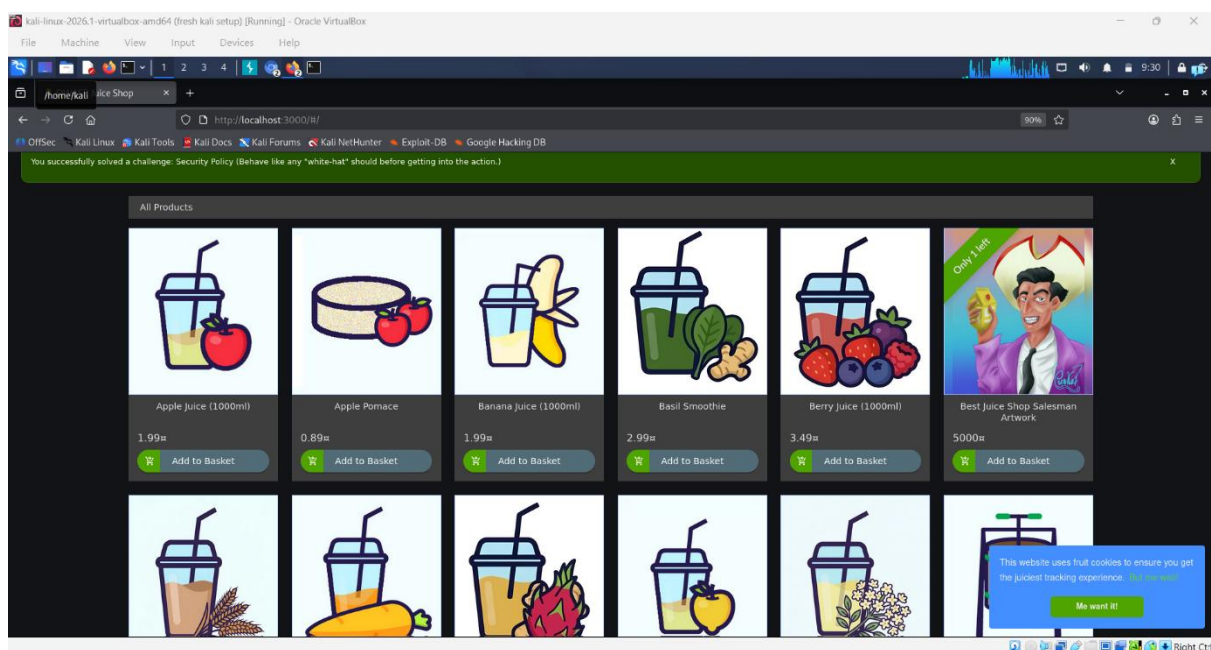
Description:

The OWASP Juice Shop application was started using Docker and accessed through a web browser. This application served as the target environment for performing web application security testing activities.

Result:

The application was successfully launched and made accessible through the local browser.

Evidence:



Activity 2: HTTP Traffic Analysis Using Burp Suite

Description:

Burp Suite Community Edition was launched and configured. The application traffic was routed through Burp Suite to observe HTTP requests and responses generated while browsing OWASP Juice Shop.

HTTP requests and responses were successfully captured and analyzed.

Evidence:

Burp Suite Community Edition v2026.3.2 - Temporary Project

Dashboard Target Proxy Intruder Repeater Sequencer Decoder Compiler Logger Organizer Extensions Discover

Interval HTTP history Websockets history Match and replace Proxy settings

Filter settings: Hiding CSS and Image contents; Hiding specific extensions

	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start response...
1	http://localhost:3000	GET	/			200	10370	HTML		OZAWAP Juice Shop			127.0.0.1		08-48-20.23.1	8080	1469
18	http://localhost:3000	GET	/assets/fonts/monospace			304	392	JSON					127.0.0.1		08-48-29.23.1	8080	6577
19	http://localhost:3000	GET	/rest/admin/application-configuration			304	306						127.0.0.1		08-48-29.23.1	8080	2458
20	http://localhost:3000	GET	/socket.io/?EIO=3&transport=polling&_			200	326	text	io/				127.0.0.1		08-48-29.23.1	8080	539
21	http://localhost:3000	GET	/rest/admin/application-version			304	304						127.0.0.1		08-48-29.23.1	8080	926
12	http://localhost:3000	GET	/rest/user/auth/login?fields=email&			200	1173	JJSON					127.0.0.1	token=myR0xKAUCh	08-48-29.23.1	8080	1749
13	http://localhost:3000	GET	/api/challenges?name=&score%20=&			200	862	JJSON					127.0.0.1		08-48-29.23.1	8080	33615
14	http://localhost:3000	GET	/rest/flags			200	416	JJSON					127.0.0.1		08-48-31.23.1	8080	32388
15	http://localhost:3000	GET	/rest/languages			304	306	JJSON					127.0.0.1		08-48-31.23.1	8080	30639
17	http://localhost:3000	GET	/rest/user/teams			200	384	JJSON					127.0.0.1		08-48-32.23.1	8080	6476
18	http://localhost:3000	GET	/socket.io/?EIO=3&transport=websock.			101	129		io/				127.0.0.1		08-48-35.23.1	8080	4770
19	http://localhost:3000	GET	/api/quantify			200	8016	JJSON					127.0.0.1		08-48-37.23.1	8080	29373
20	http://localhost:3000	GET	/rest/researcher/status			200	16993	JJSON					127.0.0.1		08-48-38.23.1	8080	24465

Event log (0) All issues

Memory: 123.0MB of 494.0MB Disabled

Activity 3: Request Inspection

Description:

Captured requests were examined to understand request methods, URLs, headers, and server responses. This activity helped in understanding client-server communication within web applications.

Result:

Request and response details were successfully inspected.

Evidence:

[illegible]

Activity 4: Burp Repeater Analysis

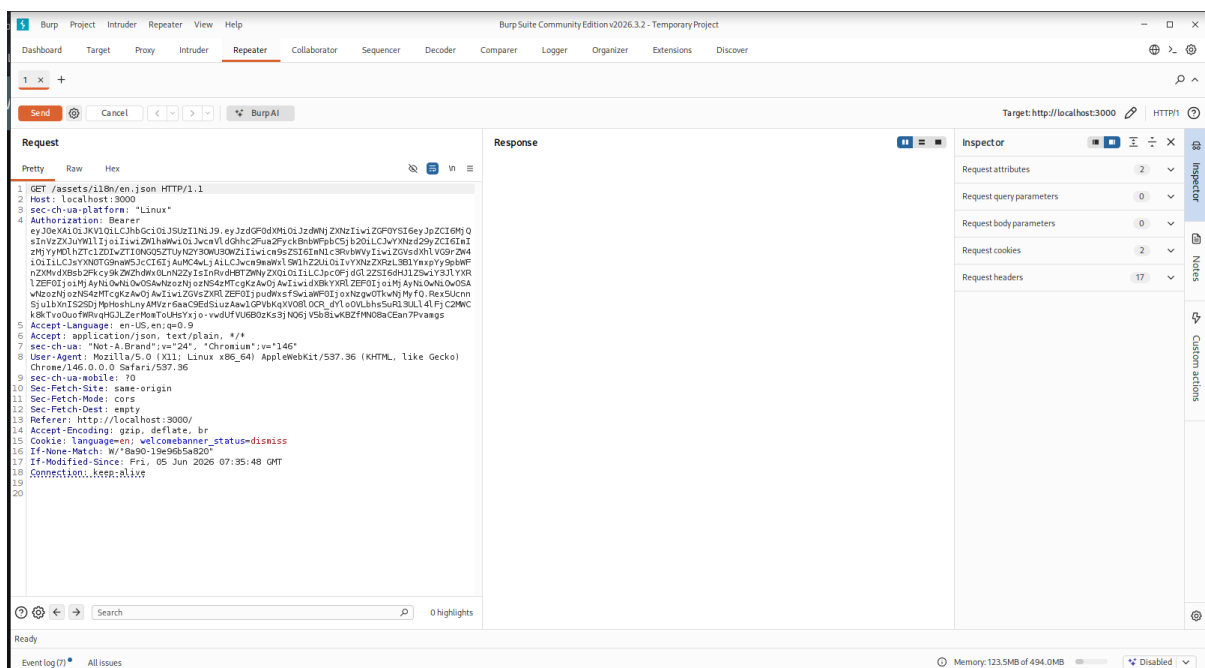
Description:

Captured HTTP requests were sent to the Burp Repeater module for analysis. The structure of requests and corresponding responses were observed.

Result:

Requests were successfully reviewed using the Repeater tool.

Evidence:



Activity 5: Directory Discovery Using Dirsearch

Description:

Dirsearch was executed against the OWASP Juice Shop application to perform directory and endpoint discovery.

Result:

Directory enumeration was initiated successfully and application paths were analyzed.

Evidence:

```
(kali@kali)~$ dirsearch -u http://localhost:3000
/usr/lib/python3/dist-packages/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3
Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Output File: /home/kali/reports/http_localhost_3000/_26-06-23_09-01-22.txt
Target: http://localhost:3000/
09:01:22] Starting: 3% 432/11460 70/s job:1/1 errors:0
```

5. Security Concepts Studied

SQL Injection

Definition:

SQL Injection is a web application vulnerability that occurs when untrusted user input is processed improperly before interacting with a database.

Impact:

- Unauthorized access to data
- Data disclosure
- Data manipulation
- Authentication bypass

Mitigation:

- Parameterized queries
- Input validation
- Least privilege access controls

Cross-Site Scripting (XSS)

Definition:

Cross-Site Scripting (XSS) is a vulnerability that allows unintended scripts to execute within a user's browser.

Impact:

- Session compromise
- User impersonation
- Website defacement
- Data theft

Mitigation:

- Input validation
- Output encoding
- Content Security Policy (CSP)

6. Key Learning Outcomes

During this task, the following concepts were learned:

- Web Application Security Fundamentals
- HTTP Request and Response Analysis
- Traffic Inspection Using Burp Suite
- Request Analysis Using Repeater
- Directory Discovery Using Dirsearch
- Understanding SQL Injection Concepts
- Understanding Cross-Site Scripting Concepts
- Security Testing Documentation

8. Conclusion

This task provided practical exposure to web application security testing concepts using OWASP Juice Shop in a controlled environment. Security testing tools such as Burp Suite and Dirsearch were utilized to analyze application behavior, inspect HTTP traffic, and understand web application security assessment methodologies. The exercise improved knowledge of common web vulnerabilities, testing workflows, and penetration testing documentation practices.